Acceso remoto seguro en Windows

Auditoría mediante PowerShell, JSON y aplicación web interactiva

Autores: Kevin Urbina y Luis Alonso Huertas

Entorno: Windows 11 (Laboratorio W11-KUR)

Contexto: Defensa Universitaria (ISW-612)

Gemini Notebook

El riesgo del acceso remoto sin restricciones



¿Qué es el acceso remoto?

Es la capacidad de administrar un equipo a distancia sin estar físicamente frente a él. Facilita el trabajo, pero abre 'puertas' en el sistema.

Propósito Legítimo

Implementado correctamente, permite a los administradores gestionar servidores y sistemas de forma eficiente y segura desde cualquier lugar, mejorando la productividad y la capacidad de respuesta.



El Problema

Si la configuración es débil o predeterminada, la puerta queda expuesta a conexiones maliciosas continuas.

Ataques de fuerza bruta

Un método donde un atacante intenta adivinar credenciales probando miles de combinaciones de usuario y contraseña a gran velocidad hasta lograr entrar.

Gemini Notebook

Matriz de acceso remoto seguro



RDP

Interfaz gráfica que permite ver y controlar el escritorio a distancia.



NLA

El "guardia en la puerta". Exige comprobar quién eres antes de siquiera mostrarte la pantalla de RDP.



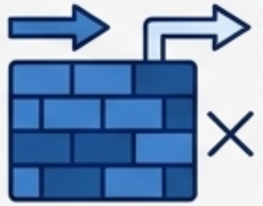
WinRM

Herramienta nativa para administrar el equipo mediante comandos invisibles a través de la red.



OpenSSH

Herramienta estándar y multiplataforma para acceder al sistema de forma segura por terminal de texto.



Firewall de Windows

El filtro de tráfico. Decide qué conexiones de red tienen permiso para entrar o salir del equipo.

Gemini Notebook

¿Qué buscamos medir y qué esperábamos encontrar?



Pregunta de Investigación

¿Qué configuraciones de RDP, WinRM y OpenSSH reducen el riesgo de fuerza bruta en Windows y cómo se mide esa reducción?



Hipótesis Inicial

Lo que creíamos:

Un sistema Windows con su configuración inicial predeterminada es deficiente y obtendrá menos de 50/100 en seguridad.

Lo que esperábamos:

Al aplicar un 'endurecimiento' estricto (controles, NLA, Firewall), el puntaje superará los 80/100 y los ataques masivos serán bloqueados automáticamente.

Gemini Notebook

Arquitectura del proyecto: De la extracción a la visualización

VM Windows 11 (laboratorio)

- RDP / NLA
- WinRM
- OpenSSH
- Firewall
- Política de bloqueo

Consulta / auditoría

Script PowerShell

- Audita configuración
- Verifica servicios y puertos
- Detecta intentos fallidos
- Evalúa controles de seguridad
- Genera resultados

Exporta resultados

Archivo JSON

```
{
  "servicio": "RDP",
  "habilitado": true,
  "puerto": 3389,
  "autenticación": "NLA",
  "reglas_firewall": "Permitido",
  "politica_bloqueo": "Activa",
  "riesgo": "Bajo",
  "puntaje": 85
}
```

Carga de datos

Aplicación web

- Carga el JSON
- Muestra checklist
- Calcula puntaje 0–100
- Presenta riesgos detectados
- Sugiere recomendaciones

Flujo de datos

Configuración del sistema → Resultados de auditoría → Visualización y checklist

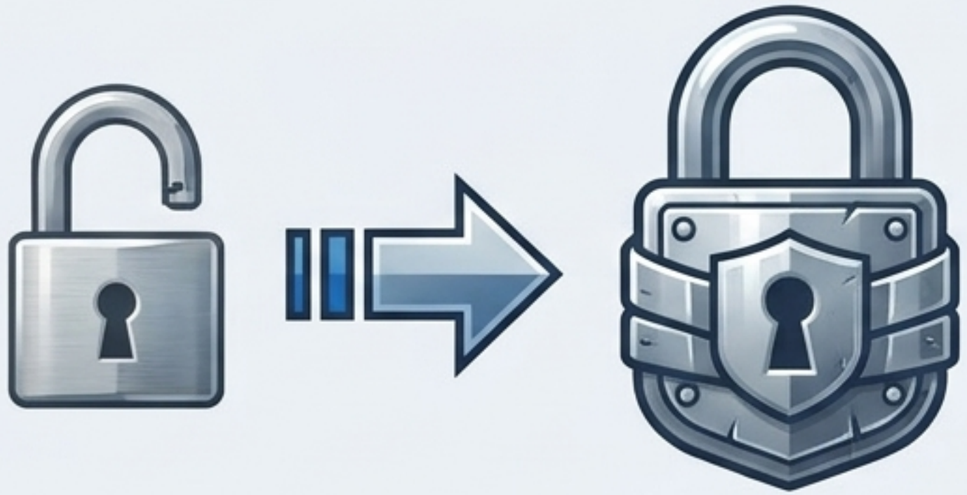
Objetivo: evaluar la configuración de acceso remoto seguro y mostrar el resultado de forma visual e interactiva.

Nota: El puntaje de 0 a 100 es un modelo académ... para este proyecto, no una escala oficial de Micr...

Gemini Notebook

Endurecimiento: Reforzando las defensas del sistema

¿Qué es el endurecimiento de seguridad (Hardening)?



Es el proceso de tomar la configuración inicial de un sistema y aplicar medidas mucho más estrictas para reducir su vulnerabilidad ante ataques.

¿Cómo funciona la política de bloqueo de cuentas?



Umbral de bloqueo

¿Cuántos intentos de contraseña fallidos toleramos antes de actuar? (Ej. 5 intentos).



Duración del bloqueo

Una vez bloqueado el usuario, ¿cuánto tiempo debe esperar el atacante como castigo? (Ej. 15 minutos).



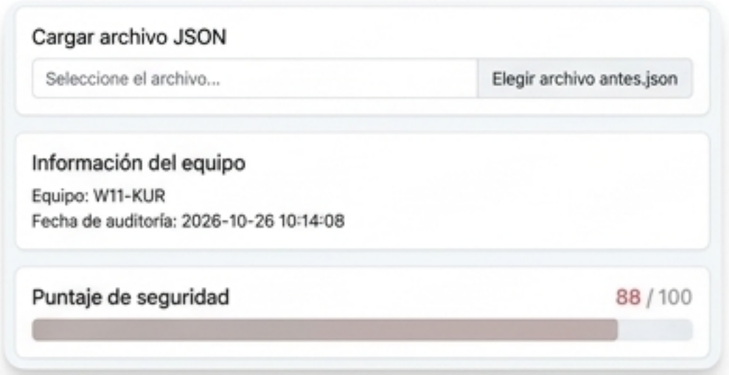
Ventana de observación

¿Por cuánto tiempo el sistema 'recuerda' los intentos fallidos antes de perdonarlos y reiniciar el contador a cero?

Gemini Notebook

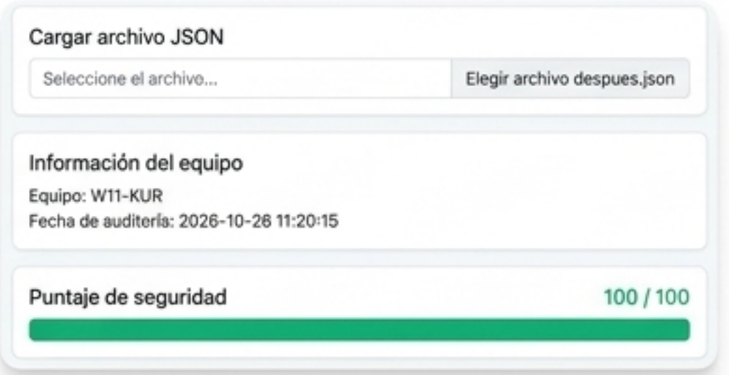
Resultados: Comparación real del endurecimiento

Configuración antes del endurecimiento



Umbral de bloqueo:	10 intentos
Duración del castigo:	10 minutos
Ventana de memoria:	10 minutos
Estado:	La configuración inicial de Windows 11 base.

Después del endurecimiento



Umbral de bloqueo:	5 intentos (Más estricto)
Duración del castigo:	15 minutos (Mayor castigo al atacante)
Ventana de memoria:	10 minutos
Estado:	Endurecimiento aplicado. No hay alertas críticas.

Gemini Notebook

Prueba controlada de bloqueo en acción

La Prueba: Se dirigieron deliberadamente 5 intentos fallidos consecutivos contra la cuenta local de laboratorio: pruebaISW612.

Evidencia 1: El Sistema Interno

```
Status: Lockout = True
```

El sistema confirmó instantáneamente que la cuenta fue suspendida para protegerse del bombardeo.



Evidencia 2: El Registro Oficial

```
Evento de Seguridad
Registrado: 4740
```

Windows dejó constancia formal y auditable de que bloqueó un usuario por motivos de seguridad, esencial para cualquier auditoría real.

Gemini Notebook

Limitaciones y alcance real del experimento



Entorno Aislado

Todas las pruebas se limitaron a un laboratorio controlado en la VM W11-KUR. No se realizaron ataques contra equipos externos.



Simulación Interactiva

La fuerza bruta fue ejecutada manualmente en el entorno local de la VM, no mediante scripts automatizados desde otra red.



Sin Bloqueo por IP

Se utilizó el mecanismo nativo de bloqueo de cuenta de Windows, pero no se implementó un bloqueo dinámico de dirección IP en el Firewall.



Aislamiento de la Prueba

Durante el experimento de bloqueo, los servicios RDP, WinRM y OpenSSH permanecieron intencionalmente deshabilitados para evitar interferencias.

Gemini Notebook

Conclusiones finales y aprendizaje

Evaluación del Proyecto

✅❌

✅ La arquitectura construida (PowerShell → JSON → Web) es eficaz para auditar y visualizar la seguridad sin requerir perfiles técnicos avanzados.

❌ **Hipótesis parcialmente apoyada:** El endurecimiento mejoró la seguridad y alcanzó los 100/100, logrando bloquear ataques reales. Sin embargo, la predicción de una base débil (<50/100) falló: Windows 11 en su configuración inicial predeterminada resultó ser sorprendentemente robusto (88/100).

Aprendizaje con IA



Uso de Inteligencia Artificial

La Inteligencia Artificial se utilizó para la recopilación inicial de referencias y bibliografía.

Lección aprendida:
La validación humana fue obligatoria. Se debieron descartar sitios sugeridos no oficiales y verificar la vigencia de los enlaces aportados por la IA.

Gemini Notebook